Pràctica: validació d'un formulari de registre amb PHP

M613-B1 · Desenvolupament web en entorn servidor

Objectiu

Crear un formulari de registre d'usuari amb **validació al servidor**, gestió d'errors mitjançant **sessions**, persistència de les dades als camps del formulari i les **mesures de seguretat** que hem treballat a classe: escapar la sortida amb `htmlspecialchars()`, token CSRF i acceptar només peticions POST.

Descripció

L'usuari omple el formulari i l'envia. Si alguna dada no és correcta, torna al formulari, veu els errors sota cada camp i conserva el que havia escrit. Si totes les dades són correctes, veu un resum a la pàgina de resultat.

Pas	Pàgina	Què passa
1	`registre.php`	Mostra el formulari (amb errors i valors anteriors, si n'hi ha).
2	`valida_registre.php`	Rep el POST, comprova el token, valida tots els camps.
3a	→ `registre.php`	Si hi ha errors: desa errors i dades a la sessió i redirigeix.
3b	→ `resultat.php`	Si tot és correcte: desa les dades validades a la sessió i redirigeix.

Estructura de fitxers

```
/practica_validacio/
├── index.php              // Pàgina principal amb enllaç al registre
├── registre.php           // Formulari de registre
├── valida_registre.php    // Rep el formulari, valida i redirigeix
├── resultat.php           // Resum de les dades validades
├── css/
│   └── estils.css         // Estils del sistema
└── includes/
    ├── header.php         // Capçalera i menú comuns
    ├── footer.php         // Peu comú
    └── validacio.php      // Funcions de validació
```

Requisits per pàgina

1. index.php

- Títol "Benvingut/da al Sistema" i una breu descripció del sistema.
- Enllaç destacat "Registre d'Usuari".
- Peu de pàgina amb copyright i l'any actual generat amb `date('Y')`.

2. registre.php

- Títol "Registre d'Usuari" i enllaç per tornar a l'índex.
- Formulari amb tots els camps, cadascun amb el seu `<label>`, que envia les dades a `valida_registre.php` amb **POST**.
- Si hi ha errors a la sessió, mostrar cada error **sota el seu camp** i marcar visualment els camps amb error (per exemple, amb una classe CSS).
- Mantenir els valors introduïts. Tot valor que es torni a escriure a la pàgina ha de passar per `htmlspecialchars()`.
- Un cop mostrats, **esborrar els errors i les dades de la sessió**, perquè no tornin a sortir si es recarrega la pàgina.
- Incloure un camp ocult amb el **token CSRF** guardat a la sessió.

3. valida_registre.php

1. Si la petició no és POST, redirigir a `registre.php`.
2. Comprovar el token CSRF amb `hash_equals()`. Si no coincideix, respondre amb el codi 403 i aturar l'execució.
3. Per a cada camp: comprovar que existeix i que és un string, aplicar `trim()` i validar-lo segons els criteris de la taula. Les normalitzacions (minúscules, treure espais, majúscula inicial…) es fan tal com indica la taula.
4. Si hi ha errors: desar els errors i les dades enviades a la sessió i redirigir a `registre.php`.
5. Si tot és correcte: desar les dades validades a la sessió i redirigir a `resultat.php`.

⚠️ **Aquí no s'escapa ni es "neteja" res.** No feu servir `strip_tags()` ni `htmlspecialchars()` en aquest fitxer: una dada que no és correcta es **rebutja** amb un missatge d'error. L'escapament es fa a la **sortida**, a `registre.php` i `resultat.php`. Recordeu també posar `exit` després de cada `header('Location: ...')`.

4. resultat.php

- Si s'hi accedeix sense dades validades a la sessió, redirigir a `registre.php`.
- Mostrar totes les dades en format llegible (llista o taula), escapades amb `htmlspecialchars()`. Si el telèfon és buit, mostrar "No indicat".
- Després de mostrar-les, esborrar les dades de la sessió.
- Enllaç per tornar a `index.php`.

Criteris de validació

Camp	Obligatori	Regles	Normalització	Exemples
👤 **Nom**	Sí	Entre 2 i 50 caràcters. Lletres (també amb accent), espais, apòstrofs i guions.	`trim()`	✅ Núria, l'Anna, Maria-Núria ❌ A, Joan3, <script>

Camp	Obligatori	Regles	Normalització	Exemples
📧 **Email**	Sí	Format d'email vàlid.	Passar a minúscules.	✅ ANNA@Lacetania.cat → anna@lacetania.cat ❌ anna@, anna.lacetania.cat
🔢 **Edat**	Sí	Nombre enter entre 18 i 120, sense decimals.	Es desa com a `int`.	✅ 18, 45 ❌ 17, 18.5, 1e3, abc
📱 **Telèfon**	No	Si s'omple, ha de tenir exactament 9 dígits.	Treure espais i guions abans de validar.	✅ 666 12 34 56 → 666123456 ❌ 12345, 666a12345
🌆 **Població**	Sí	Entre 2 i 50 caràcters. Lletres, espais, apòstrofs i guions.	Primera lletra en majúscula.	✅ manresa → Manresa ✅ la Seu d'Urgell → La Seu d'Urgell ❌ M, 08240

💡 **Pista UTF-8:** les funcions clàssiques treballen amb bytes, no amb lletres. `ucfirst("àger")` retorna "àger" sense canviar res. Feu servir les funcions `mb_*` i expressions regulars amb el modificador `u`.

includes/validacio.php

Agrupeu la validació en funcions, una per camp, que retornin el missatge d'error o `null` si el valor és correcte. Per exemple:

```
function validarNom(string $nom): ?string
{
    // ...
}
```

Millora opcional: en lloc de funcions, implementar una classe validadora com la de l'exemple de les diapositives.

Elements comuns i estils

- Capçalera, menú de navegació senzill i peu de pàgina comuns a totes les pàgines, amb `include`.
- Paleta de colors i tipografia coherents, marges i espaiat adequats.
- Botons i enllaços ben destacats; missatges d'error clarament visibles.

Proves obligatòries

El vídeo ha de mostrar aquestes proves, **en aquest ordre**. Indiqueu a la pantalla el número de cada prova.

#	Prova	Resultat esperat
1	Enviar el formulari buit.	Errors a nom, email, edat i població. El telèfon no dona error.
2	Nom `l'Anna`, població `la seu d'urgell` i la resta correcte.	Es mostra el resultat amb la població "La Seu d'Urgell".
3	Nom `<script>alert(1)</script>`.	Error al nom. Al camp es veu el text tal qual i no s'executa cap alerta.
4	Edat `17`, després `18.5` i després `1e3`.	Error en els tres casos.
5	Email `ANNA@Lacetania.CAT`.	Al resultat surt anna@lacetania.cat.
6	Telèfon `666-12-34-56` i, després, telèfon `12345`.	El primer es desa com a 666123456; el segon dona error.
7	Error en un sol camp.	La resta de camps conserven el valor escrit.
8	Recarregar `registre.php` després d'un error.	L'error ja no surt.
9	Obrir `resultat.php` directament.	Redirigeix a `registre.php`.
10	Obrir `valida_registre.php` directament al navegador.	Redirigeix a `registre.php`.
11	Modificar el token CSRF amb F12 i enviar.	La petició es rebutja (403).
12	Treure `maxlength` i `required` amb F12 i enviar un nom de 60 caràcters.	El servidor mostra l'error del nom.

Entrega

- Fitxer .zip amb tot el codi font, degudament comentat.
- Vídeo de 3 minuts com a màxim, sense explicacions, que mostri les 12 proves.

Avaluació (sense vídeo no es pot aprovar la tasca)

Criteri	Pes	Excel·lent	Adequat	Insuficient
Validació dels camps	30%	Tots els criteris i normalitzacions correctes, també amb accents i apòstrofs.	La majoria de criteris correctes; falla algun cas límit.	Falten camps o la validació es pot saltar.
Errors i sessions	20%	Errors sota cada camp, valors conservats, sessió esborrada després de mostrar-los, redireccions correctes.	Funciona, però amb algun detall (errors que persisteixen, algun valor perdut).	No hi ha persistència o els errors no es mostren per camp.
Seguretat	20%	`htmlspecialchars()` a tota la sortida, token CSRF, només POST, `resultat.php` protegit, cap neteja a l'entrada.	Hi ha la majoria de mesures, però en falta alguna.	Hi ha XSS o falten diverses mesures.
Estructura i codi	15%	Includes comuns, `validacio.php`, codi net i ben comentat.	Estructura correcta però amb codi repetit o pocs comentaris.	Tot en un fitxer o codi difícil de seguir.
Disseny i CSS	10%	Coherent, clar i amb errors ben visibles.	Correcte però poc treballat.	Sense estils o poc llegible.
Vídeo	5%	Mostra les 12 proves en ordre.	Falta alguna prova.	No mostra les proves.